Figure 4.12 In the hash-based double-submit cookie pattern, the anti-CSRF token is computed as a secure hash of the session cookie. As before, a malicious client is unable to guess the correct value. However, they are now also prevented from overwriting the CSRF cookie because they cannot compute the hash of the session cookie.

The security of this scheme depends on the security of the hash function. If the attacker can easily guess the output of the hash function without knowing the input, then they can guess the value of the CSRF cookie. For example, if the hash function only produced a 1-byte output, then the attacker could just try each of the 256 possible values. As the CSRF cookie will be accessible to JavaScript and might be accidentally sent over insecure channels, while the session cookie isn't, the hash function should also make sure that an attacker is not able to reverse the hash function to discover the session cookie value if the CSRF token value accidentally leaks. In this chapter, you will use the *SHA-256* hash function. SHA-256 is considered by most cryptographers to provide both security properties.

> **DEFINITION *SHA-256*** is a cryptographically secure hash function designed by the US National Security Agency that produces a 256-bit (32-byte) output value. SHA-256 is one variant of the SHA-2 family of secure hash algorithms specified in the Secure Hash Standard (https://doi.org/10.6028/NIST.FIPS.180-4), which replaced the older SHA-1 standard that is no longer considered secure. SHA-2 specifies several other variants that produce different output sizes,